

Report Vulnerability Assessment: Metasploitable 2

Data: 07 Gennaio 2026
Target: 192.168.1.105 (Metasploitable 2)
Strumento: Tenable Nessus
Configurazione Porte: Common Ports (Standard)

1. Sintesi

Il presente rapporto documenta i risultati dell'attività di Vulnerability Assessment condotta sul target **Metasploitable 2**. L'analisi, effettuata tramite lo scanner **Nessus**, ha evidenziato una postura di sicurezza estremamente critica.

La scansione, limitata alle **porte più comuni (Common Ports)** come da configurazione, ha comunque rilevato un numero elevato di vulnerabilità di livello **Critical e High**. Sono state identificate backdoor attive, servizi obsoleti, credenziali di default e configurazioni errate che permetterebbero a un attaccante di ottenere il controllo completo del sistema (Root Access) in pochi minuti.

2. Introduzione

L'obiettivo dell'attività è stato identificare, quantificare e prioritizzare le vulnerabilità presenti sull'host target. A differenza di un Penetration Test, questa fase si è limitata all'identificazione automatizzata e alla verifica delle firme delle vulnerabilità senza procedere allo sfruttamento attivo (exploitation) massivo, se non per verifiche di conferma.

2.1 Ambito e Metodologia

- **Target:** Metasploitable 2 (Linux/Ubuntu 8.04).
- **Strumento:** Nessus Vulnerability Scanner.
- **Policy di Scansione:** Basic Network Scan.
- **Port Scanning Strategy:** "Common Ports" (Analisi delle porte standard definite nel database dei servizi, es. 21, 22, 80, 445, 3306, ecc.).

3. Panorama delle Minacce Rilevate

La scansione ha restituito il seguente profilo di rischio:

Livello di Rischio	Conteggio	Descrizione Impatto
CRITICAL	6	Compromissione

		immediata del sistema (RCE, Backdoor).
HIGH	6	Alta probabilità di compromissione (Weak Creds, Exploit noti, outdated soft.).
mixed	8	
MEDIUM	16	Configurazioni insicure (SSL debole, Info Disclosure, outdated certificates.).
LOW	5	(Problemi minori di configurazione, icmp timestamps).
INFO	40+	Informazioni di ricognizione (OS Detection, Banner).

3.1 Distribuzione per Servizio

Le criticità maggiori si concentrano sui servizi di amministrazione remota e file sharing:

- **IRC (6667/TCP):** Presenza di Backdoor.
- **HTTP (80 TCP):** no support
- **VNC (5900 TCP):** controllo remoto
- **RCE (8009 TCP):** controllo remoto
- **Remote Shell (5432/25/22TCP):** Accesso root diretto.

4. Analisi delle Vulnerabilità Emergenti

Di seguito si riportano le vulnerabilità più significative identificate, raggruppate per tipologia, in linea con le tendenze di sicurezza attuali.

4.1 Backdoor e Remote Code Execution (RCE)

Nessus ha identificato servizi che permettono l'esecuzione di codice arbitrario senza autenticazione:

- **UnrealIRCd Backdoor (Porta 6667):** IRC è stato compilato con una backdoor che permette l'esecuzione di comandi con privilegi dell'utente che esegue il servizio.
- **VNC server (Porta 5900):** password debole.

- **Open SSH/SSL (Porte 5432/25):** il certificato del server remoto SSL è stato generato con un bug nel random number generator nella sua libreria open SSL.

4.2 Credenziali Deboli e Default (Social Engineering & Misconfiguration)

L'analisi delle credenziali (Brute Force Checks di Nessus) ha avuto successo su molteplici servizi:

- **SSH (Porta 22):** Credenziali default user:user e msfadmin:msfadmin rilevate.
- **VNC (Porta 5900):** Password password rilevata, permettendo il controllo grafico remoto.
- **PostgreSQL / MySQL(Porta5432):** Account di database con password di default o vuote (postgres:postgres, root:).

4.3 Software Obsoleto e Non Supportato (Supply Chain Risks)

Il sistema operativo e i servizi applicativi sono "End-of-Life" (EOL):

- **Apache Tomcat (Porta 8180):** Credenziali di default manager/tomcat e versione vulnerabile.
- **Samba (Porta 445):** Versione Samba 3.6.0 to 4.4.0 vulnerabile a un man in the middle in cui un attaccante può impersonare un server per ricevere gli stessi privilegi del client.
- **PHP:** Versione obsoleta esposta via HTTP.

5. Strategie di Difesa e Remediation Plan

In linea con il framework di difesa resiliente e il modello Zero Trust, si raccomandano le seguenti azioni correttive:

5.1 Azioni Prioritarie (Immediate)

1. **Isolamento:** Disconnettere immediatamente l'host dalla rete di produzione.
2. **Patching/Rimozione:**
 - Rimuovere o aggiornare **vsftpd** e **UnrealIRCd** a versioni pulite e stabili.
3. **Hardening Credenziali:**
 - Modificare tutte le password di default (SSH, DB, VNC).
 - Disabilitare l'autenticazione root via SSH.

5.2 Strategia a Lungo Termine (Zero Trust)

- **Segmentazione di Rete:** Collocare servizi vulnerabili legacy in VLAN isolate con firewalling stretto.
- **Autenticazione Forte (MFA):** Implementare autenticazione a chiavi pubbliche per SSH e dismettere Telnet a favore di protocolli cifrati.
- **Vulnerability Management Continuo:** Programmare scansioni Nessus ricorrenti (settimanali) per monitorare l'efficacia delle patch.

6. Conclusioni

L'host analizzato rappresenta un rischio estremo. La combinazione di software obsoleto, configurazioni di default e backdoor note rende la macchina compromettibile da attaccanti con scarse competenze tecniche (Script Kiddies).

È imperativo procedere con la bonifica (remediation) immediata seguendo le priorità indicate nel paragrafo 5, adottando un approccio "Security by Design" per le future implementazioni.